

## BTS SIO - Option SISR

Lycee Dominique Villars - Gap

# TD4

## Deployer des moyens de preuves securises et conformes a la legislation

*Chiffrement PGP des courriels avec ThunderBird & Enigmail*

|                    |                                  |
|--------------------|----------------------------------|
| <b>Eleve</b>       | Mohammed Fahad                   |
| <b>Classe</b>      | BTS SIO 1ere annee - Option SISR |
| <b>Professeurs</b> | M. Sotoca / M. Falzon            |
| <b>Date</b>        | Mai 2026                         |

# Introduction

---

Dans le cadre de ce TD4, la mission consiste a deployer et a tester une solution de chiffrement des courriels basee sur la technologie PGP (Pretty Good Privacy). Cette technologie s'inscrit dans une demarche de renforcement des moyens de preuves securises et de conformite avec la legislation en vigueur, notamment le RGPD et les recommandations de la CNIL.

PGP est un standard de cryptographie asymetrique, c'est-a-dire qu'il repose sur deux cles complementaires : une cle publique, librement distribuee, qui permet de chiffrer un message, et une cle privee, confidentielle, qui est la seule a pouvoir le dechiffrer. En plus du chiffrement, PGP permet la signature numerique des messages, ce qui garantit l'identite de l'expediteur et l'integrite du contenu.

La mise en oeuvre se fait dans un environnement virtualise prototypant un echange entre une banque fictive M@Banque et l'un de ses clients. Le client de messagerie utilise est ThunderBird, associe au module complementaire Enigmail qui integre les fonctions PGP directement dans l'interface.

## 1. Mise en place de l'environnement de test

---

### 1.1 Architecture reseau

L'environnement de test est compose de deux machines virtuelles Debian importees dans VirtualBox. Ces deux machines sont connectees en reseau interne, ce qui signifie qu'elles peuvent communiquer entre elles mais restent isolees du reseau physique de l'hote. Ce type de configuration est ideal pour tester des protocoles reseau sans impacter l'infrastructure reelle.

| Parametre              | VM MaBanque             | VM ClientMaBanque             |
|------------------------|-------------------------|-------------------------------|
| Systeme d'exploitation | Debian                  | Debian                        |
| Adresse IP             | 192.168.0.1 /24         | 192.168.0.2 /24               |
| Client de messagerie   | ThunderBird             | ThunderBird                   |
| Compte messagerie      | protomabanque@gmail.com | clientprotomabanque@gmail.com |
| Phrase de passe PGP    | mabanque                | clientmabanque                |

### 1.2 Import des machines virtuelles

Les deux machines virtuelles ont été importées depuis le fichier fourni (format .ova) via le menu Fichier > Importer un appareil virtuel de VirtualBox. L'assistant d'importation permet de choisir le dossier de destination et les ressources allouées (RAM, CPU). Une fois importées, les deux VM apparaissent dans la liste des machines disponibles.

Avant de démarrer les tests, la connectivité réseau entre les deux machines a été vérifiée en exécutant un ping depuis la VM mabanque vers l'adresse 192.168.0.2 (VM clientmabanque). Une réponse positive confirme que les deux machines peuvent bien communiquer, condition nécessaire pour que les échanges de courriels fonctionnent.

## 2. Configuration des comptes de messagerie ThunderBird

---

### 2.1 Création des comptes et choix de la langue

Sur chaque machine virtuelle, ThunderBird a été configuré avec un compte de messagerie distinct. La procédure de création d'un compte dans ThunderBird consiste à renseigner le nom d'affichage, l'adresse email et le mot de passe, puis à laisser ThunderBird détecter automatiquement les paramètres IMAP/SMTP du fournisseur (ici Gmail). Pour les comptes Gmail, il est nécessaire d'activer l'accès IMAP dans les paramètres du compte Google et de générer un mot de passe d'application spécifique si la validation en deux étapes est activée.

Le pack de langue français (Français Language Pack) a également été installé depuis le gestionnaire de modules complémentaires de ThunderBird afin d'avoir une interface entièrement en français, ce qui facilite la navigation et la configuration du module Enigmail.

**!** *Les adresses Gmail utilisées sont des adresses de test dédiées à l'environnement prototype. Elles ne contiennent pas de données réelles de clients.*

### 2.2 Installation et configuration du module Enigmail

Enigmail est un module complémentaire open source pour ThunderBird qui permet d'intégrer de manière transparente le chiffrement et la signature numérique PGP dans le processus d'envoi et de réception des courriels. Il agit comme une interface graphique au-dessus de GnuPG (GNU Privacy Guard), le moteur de chiffrement installé sur le système.

La procédure d'installation d'Enigmail se déroule comme suit : dans ThunderBird, aller dans Outils > Modules complémentaires et extensions, puis rechercher 'Enigmail' dans la barre de recherche. Une fois le module trouvé, cliquer sur 'Ajouter à ThunderBird' et accepter les permissions demandées. ThunderBird redémarre ensuite automatiquement pour activer le module.

Après le redémarrage, un nouveau menu 'Enigmail' apparaît dans la barre de menus de ThunderBird. Un assistant de configuration se lance la première fois pour guider l'utilisateur dans la création de sa paire de clés PGP.

## 2.3 Generation des paires de cles PGP

La cryptographie asymetrique utilisee par PGP repose sur une paire de cles mathematiquement liees. La cle publique peut etre librement partagee avec n'importe qui : elle sert a chiffrer les messages a destination du proprietaire. La cle privee, en revanche, doit rester strictement confidentielle : c'est elle qui permet de dechiffrer les messages recus et de signer les messages envoyes.

Pour generer la paire de cles, on accede au menu Enigmail > Gestion des cles, puis on clique sur Generer > Nouvelle paire de cles. L'assistant demande de choisir le compte de messagerie associe, de definir une date d'expiration pour la cle (recommande pour des raisons de securite), et de saisir une phrase de passe robuste. Cette phrase de passe protege la cle privee : elle est demandee a chaque fois que l'utilisateur souhaite signer ou dechiffrer un message.

Les parametres de generation utilises dans ce TP sont les suivants : algorithme RSA avec une longueur de 4096 bits, ce qui offre un niveau de securite tres eleve et est conforme aux recommandations actuelles de l'ANSSI (Agence Nationale de la Securite des Systemes d'Information). La phrase de passe correspond au mot de passe defini dans le cahier des charges : 'mabanque' pour le compte de la banque, et 'clientmabanque' pour le compte du client.

**!** *La phrase de passe utilisee dans ce TP est volontairement simple car il s'agit d'un environnement de test. Dans un contexte reel, une phrase de passe longue, complexe et unique est indispensable.*

## 3. Test de l'envoi de courriels et verification du chiffrement

### 3.1 Envoi d'un courriel sans chiffrement (reference)

Avant d'activer le chiffrement, un premier courriel de test a ete envoye en clair entre les deux comptes. L'objectif est d'etablir une reference et de constater la difference de comportement entre un message non protege et un message chiffre par PGP.

En affichant la source brute du message reçu (menu Affichage > Source du message, ou raccourci Ctrl+U), on peut observer le corps du message directement lisible. Si ce message etait intercepte lors de son transit sur le reseau (par exemple par une attaque de type 'man-in-the-middle' ou par l'acces non autorise au serveur de messagerie), son contenu serait entierement visible. C'est precisement cette vulnerabilite que le chiffrement PGP permet d'eliminer.

### 3.2 Envoi d'un courriel chiffre avec PGP

Pour envoyer un courriel chiffre, il faut disposer de la cle publique du destinataire (voir partie 4 pour l'echange des cles). Une fois la cle importee, lors de la redaction d'un nouveau message

dans ThunderBird, Enigmail detecte automatiquement la disponibilite de la cle et propose le chiffrement via un bouton cadenas dans la barre d'outils de la fenetre de composition.

Lors de l'envoi, Enigmail demande la phrase de passe de la cle privee de l'expediteur afin de signer numeriquement le message. Cette saisie confirme que c'est bien le proprietaire legitime de la cle qui envoie le message. Le message est ensuite chiffre avec la cle publique du destinataire avant d'etre transmis au serveur SMTP de Gmail.

A la reception, ThunderBird avec Enigmail dechiffre automatiquement le message grace a la cle privee du destinataire. Un bandeau de securite s'affiche en haut du message indiquant : le statut du dechiffrement (succes ou echec), et le resultat de la verification de la signature numerique (valide ou invalide). Ces informations constituent des elements de preuve essentiels en cas de litige.

### 3.3 Verification que le contenu est bien chiffre

Pour s'assurer que le chiffrement est bien effectif, on affiche la source brute du message chiffre (Ctrl+U). Contrairement au message en clair vu precedemment, le corps du message apparait sous la forme d'un bloc de texte encode en Base64, encadre par les balises suivantes :

```
-----BEGIN PGP MESSAGE-----  
[ donnees chiffrees illisibles en Base64 ]  
-----END PGP MESSAGE-----
```

Ce bloc est completement inintelligible sans la cle privee du destinataire. Meme si un attaquant parvenait a intercepter ce message lors de son transit, il serait incapable d'en lire le contenu. La securite du chiffrement RSA 4096 bits garantit qu'une tentative de force brute demanderait une puissance de calcul astronomiquement superieure a ce qui est technologiquement possible aujourd'hui.

## 4. Echange des cles publiques via le serveur de cles

---

### 4.1 Principe du serveur de cles

Pour que deux utilisateurs puissent echanger des messages chiffrés avec PGP, ils doivent au préalable obtenir la cle publique de leur correspondant. La methode la plus pratique et la plus fiable consiste a utiliser un serveur de cles public (keyserver). Ces serveurs sont des annuaires en ligne qui stockent et distribuent les cles publiques PGP. Le serveur utilise dans ce TP est [keys.openpgp.org](https://keys.openpgp.org), qui est le serveur de reference recommande par la communaute OpenPGP car il verifie la propriete de l'adresse email avant de publier une cle.

### 4.2 Telechargement de sa propre cle publique (etape 1)

La premiere etape consiste a publier sa propre cle publique sur le serveur pour que les correspondants puissent la retrouver. Dans Enigmail, aller dans Gestion des cles, faire un clic

droit sur la cle souhaitee, puis selectionner 'Telecharger les cle publiques vers un serveur de cle'. Enigmail se connecte alors a `keys.openpgp.org` et envoie la cle. Le serveur renvoie un email de confirmation a l'adresse associee a la cle pour verifier que le proprietaire est bien celui qui effectue la publication.

Cette etape est effectuee sur les deux machines : la cle de `protomabanque@gmail.com` est publiee depuis la VM MaBanque, et la cle de `clientprotomabanque@gmail.com` est publiee depuis la VM ClientMaBanque. Apres confirmation par email, les deux cle sont disponibles publiquement sur le serveur.

### 4.3 Importation de la cle publique du correspondant (etape 2)

Une fois les cle publiees, chaque utilisateur doit importer la cle publique de son correspondant pour pouvoir lui envoyer des messages chiffres. Dans Enigmail > Gestion des cle > Serveur de cle > Chercher des cle, on saisit l'adresse email du destinataire. Le serveur `keys.openpgp.org` retourne la cle correspondante, qui peut alors etre importee directement dans le trousseau local d'Enigmail.

La cle importee apparait desormais dans la liste du gestionnaire de cle, identifiee par l'adresse email du correspondant et son identifiant unique (Key ID). Il est important de verifier l'empreinte (fingerprint) de la cle avec le correspondant par un autre canal (telephone, messagerie instantanee) afin de s'assurer qu'il ne s'agit pas d'une fausse cle inseree par un attaquant : c'est le principe de la verification de la confiance (Web of Trust).

**!** Dans ce TP, la verification de l'empreinte n'a pas ete effectuee car les deux machines appartiennent au meme environnement de test controle. Dans un contexte reel, cette etape est indispensable pour garantir l'authenticite des cle.

## 5. Test final des echanges chiffres

---

### 5.1 Verification des elements de securite

Avec les cle publiques mutuellement importees, les deux utilisateurs peuvent desormais s'echanger des courriels entierement chiffres et signes. Lors de chaque envoi, plusieurs indicateurs visuels dans Enigmail confirment le bon fonctionnement du chiffrement :

- Le cadenas ferme indique que le message sera chiffre avec la cle publique du destinataire
- La coche de signature indique que le message sera signe avec la cle privee de l'expediteur
- A la reception, le bandeau vert confirme que le dechiffrement a reussi et que la signature est valide
- Le bandeau affiche egalement l'identifiant de la cle utilisee, ce qui permet de tracer l'echange

Ces elements constituent ensemble une chaine de preuves numeriques : on peut prouver qu'un message specifique a bien ete envoye par un expéditeur identifié (non-repudiation), qu'il n'a pas ete modifié en transit (integrite), et qu'il etait illisible pour toute personne autre que le destinataire legitime (confidentialite).

## 5.2 Simulation d'une interception

Pour illustrer l'efficacite du chiffrement, on peut simuler une tentative d'interception en copiant la source brute d'un message chiffre et en essayant de le lire sans disposer de la cle privée du destinataire. Le resultat est un bloc de donnees entierement illisible, ce qui demontre que le chiffrement remplit bien son role de protection.

En revanche, si le meme message est ouvert dans ThunderBird sur la machine du destinataire legitime (qui possede la cle privée), Enigmail le déchiffre automatiquement et affiche le texte en clair. La difference est flagrante et demontre clairement la valeur ajoutée du chiffrement PGP dans un contexte de securisation des preuves.

## 6. Rapport - Analyse de la solution PGP

---

### 6.1 Proprietes de securite garanties

Le chiffrement PGP tel que mis en oeuvre dans ce TP repond aux quatre proprietes fondamentales de la securite de l'information, souvent resumees sous l'acronyme DICP (Disponibilite, Integrite, Confidentialite, Preuve) :

| Propriete              | Comment PGP la garantit                                                                                                                                                                                                 |
|------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Confidentialite</b> | Le contenu est chiffre avec la cle publique du destinataire. Seul le titulaire de la cle privée correspondante peut déchiffrer et lire le message, meme si le serveur de messagerie est compromis.                      |
| <b>Integrite</b>       | La signature numerique inclut un hachage du message. Si le contenu est modifié ne serait-ce d'un seul caractere apres la signature, la verification de la signature echouera et Enigmail signalera une alerte.          |
| <b>Authenticite</b>    | La signature prouve que le message a ete emis par le titulaire de la cle privée, c'est-a-dire la personne qui connait la phrase de passe. L'identite de l'expéditeur est thus certifiée.                                |
| <b>Non-repudiation</b> | L'expéditeur ne peut pas nier avoir envoye le message car la signature numerique, produite uniquement avec sa cle privée, constitue une preuve cryptographique de son envoi. C'est un element valable en cas de litige. |

### 6.2 Conformite avec la legislation

Le chiffrement PGP est pleinement conforme au cadre legal francais et europeen en matiere de protection des donnees et de securite des communications :

- Le RGPD (Reglement General sur la Protection des Donnees, applicable depuis mai 2018) impose aux organisations de mettre en oeuvre des mesures techniques appropriees pour proteger les donnees personnelles. Le chiffrement de bout en bout des communications est explicitement cite comme mesure recommandee.
- La CNIL recommande le chiffrement des echanges electroniques contenant des donnees sensibles, en particulier dans le secteur bancaire et financier.
- La directive NIS (Network and Information Security) et son successeur NIS2 renforcent les obligations de securite pour les operateurs de services essentiels, dont font partie les etablissements bancaires.
- L'article L. 1316-1 du Code civil francais reconnait la valeur probante des documents electroniques, sous reserve que leur auteur puisse etre identifie et que leur integrite soit garantie. La signature numerique PGP satisfait ces deux conditions.

### 6.3 Limites de la solution et recommandations

Malgre ses avantages considerables, le deploiement de PGP dans un environnement professionnel reel presente certaines contraintes qu'il convient de prendre en compte :

- PGP ne chiffre pas les metadonnees du message (objet, expéditeur, destinataire, date). Ces informations restent visibles sur les serveurs de messagerie et peuvent constituer une fuite d'informations.
- La gestion des cles peut devenir complexe a grande echelle : expiration des cles, revocation en cas de compromission, sauvegarde securisee des cles privees. Une politique de gestion des cles (PKI) doit etre definie.
- La phrase de passe constitue le maillon faible de la chaine : si elle est trop simple ou partagee, la securite de la cle privee est compromise. Une formation des utilisateurs est indispensable.
- En cas de perte de la cle privee ou de la phrase de passe, les messages chiffrés ne pourront plus jamais etre dechiffres. Des procedures de sauvegarde et de recuperation doivent etre prevues.



*Pour un deploiement professionnel, il est recommande de combiner PGP avec d'autres mesures : chiffrement du disque dur, authentification forte (MFA), politique de mot de passe stricte et journalisation des acces.*

## Conclusion

Ce TD4 a permis de mettre en oeuvre de maniere complete et documentee le chiffrement PGP dans un environnement de messagerie professionnelle simule. En partant de la configuration des machines virtuelles et des comptes ThunderBird, jusqu'au test d'echanges chiffrés entre les deux acteurs, chaque etape a confirme la fiabilite et la pertinence de cette technologie dans un contexte de securisation des preuves numeriques.

Les tests realises demontrent concretement que le chiffrement PGP garantit les quatre proprietes essentielles recherchees : la confidentialite (contenu illisible sans la cle privee), l'integrite (detection de toute modification), l'authenticite (identification certaine de l'expéditeur)

et la non-repudiation (preuve cryptographique de l'envoi). Ces proprietes repondent directement aux exigences legales du RGPD et aux recommandations de la CNIL pour les echanges de donnees sensibles.

En conclusion, le chiffrement PGP constitue une solution robuste, eprouvee et conforme a la legislation pour deployer des moyens de preuves securises dans les echanges electroniques professionnels. Son integration dans ThunderBird via Enigmail rend la solution accessible sans necessiter de competences cryptographiques avancees de la part des utilisateurs finaux, ce qui favorise son adoption a grande echelle au sein d'une organisation.